Plano de Segurança da Informação

Instituto Educacional Horizonte (IEH) — instituição fictícia. Versão resumida para trabalho acadêmico.

1. Introdução e objetivo do plano

Instituições de ensino reúnem muitos usuários, dados pessoais (inclusive de menores de idade), dados financeiros e sistemas dos quais dependem as aulas e a secretaria. Esse perfil atrai ataques como o ransomware (programa malicioso que bloqueia os arquivos e exige pagamento) e o phishing (mensagens falsas para roubar senhas). A Lei Geral de Proteção de Dados (LGPD, Lei nº 13.709/2018) também exige que a instituição proteja os dados pessoais que trata.

Objetivo geral: proteger os dados, equipamentos, sistemas e serviços do IEH e garantir a continuidade das atividades acadêmicas e administrativas.

Objetivos específicos: conhecer e classificar os ativos; avaliar riscos; definir controles para rede, servidores, laboratórios, computadores, site e aplicativo; planejar backup e resposta a incidentes; atender à LGPD; e definir cronograma, custos e indicadores.

Premissas. O ambiente ainda não foi auditado. Quantidades, probabilidades de risco, prazos e valores deste documento são **estimativas ou premissas a validar** em um diagnóstico técnico. Nada aqui afirma que o IEH já esteja protegido ou em conformidade com normas ou com a lei.

2. Caracterização da instituição e dos ativos de informação

2.1 Cenário

Elemento	Descrição	A validar no diagnóstico
Usuários	2.500 alunos, professores e funcionários administrativos (premissa: cerca de 150 professores e 80 funcionários)	Quantidades reais; alunos menores de 18 anos
Datacenter local	Sala própria com servidores, incluindo servidores de arquivos	Acesso físico, energia, climatização, versões dos sistemas
Site institucional	Hospedagem terceirizada	Contrato, backups do provedor, quem administra o domínio
Aplicativo institucional	Acesso a dados de alunos e responsáveis (premissa)	Quem o mantém, APIs, autenticação
Computadores	Desktops e notebooks administrativos e docentes (premissa: cerca de 120)	Idade, criptografia, antivírus, atualizações
Laboratórios	3 laboratórios com 30 computadores cada (90 máquinas)	Imagem de software, contas locais, patches
Rede	Compartilhada por alunos, professores e funcionários	Segmentação, Wi-Fi, firewall, switches
Dados	Acadêmicos, administrativos, financeiros e pessoais	Locais de armazenamento e quem acessa

2.2 Classificação dos ativos

Cada ativo é avaliado de 1 a 3 em três critérios: **sensibilidade** dos dados, **impacto da indisponibilidade** e **impacto de alteração indevida** (integridade). A soma define a criticidade: Crítico (8 a 9), Alto (6 a 7), Médio (4 a 5) e Baixo (3). As informações são rotuladas como **Pública, Interna, Confidencial ou Restrita** (dados sensíveis, financeiros e de menores).

Ativo	Criticidade (estimada)	Motivo
Sistema acadêmico (notas, matrículas)	Crítico	Dados pessoais; paralisa a secretaria
Diretório de contas (login dos usuários)	Crítico	Se cair, ninguém acessa os sistemas
Sistema de backup e cópias	Crítico	É a base da recuperação
Servidores de arquivos	Alto/Crítico	Documentos sensíveis; alvo de ransomware
Sistema financeiro e folha	Alto	Dados financeiros e pessoais
Aplicativo institucional	Alto	Dados de alunos e responsáveis
Firewall, switches e servidores de virtualização	Alto	Sustentam toda a operação
Computadores da equipe e dos laboratórios; site; Wi-Fi	Médio	Impacto limitado, mas porta de entrada de ataques

3. Principais riscos e vulnerabilidades

Os riscos foram avaliados de forma qualitativa: **risco = probabilidade (1 a 5) x impacto (1 a 5)**. Faixas: Baixo (1 a 4), Médio (5 a 9), Alto (10 a 16), Crítico (17 a 25). *Os valores abaixo são estimativas iniciais baseadas em premissas e devem ser revisados após o diagnóstico.*

Risco	Vulnerabilidades prováveis	P x I	Classe	Tratamento principal
R1 Ransomware	Rede sem segmentação, backup acessível, sistemas sem atualização	4 x 5 = 20	Crítico	Segmentação, antivírus avançado (EDR), backup imutável, atualizações
R2 Phishing e engenharia social	Pouca conscientização, ausência de MFA	5 x 4 = 20	Crítico	Treinamento, filtro de e-mail, MFA
R3 Roubo de credenciais	Senhas fracas ou repetidas, contas compartilhadas	4 x 4 = 16	Alto	MFA, senhas longas, revisão de contas
R4 Vazamento de dados pessoais	Permissões excessivas, notebooks sem criptografia	3 x 5 = 15	Alto	Menor privilégio, criptografia, programa LGPD
R5 Falha de hardware ou energia	Falta de redundância e de monitoramento	3 x 4 = 12	Alto	No-break, redundância, plano de recuperação
R6 Ataque ao aplicativo ou ao site	Componentes desatualizados, APIs sem controle	3 x 4 = 12	Alto	Testes de segurança, firewall de aplicação, contrato
R7 Perda de informações	Backup sem teste de restauração	3 x 4 = 12	Alto	Backup 3-2-1 com testes
R8 Contaminação dos laboratórios	Contas com privilégios, software não controlado	4 x 3 = 12	Alto	Gestão central, restauração das estações
R9 Acesso físico indevido ao datacenter	Chave compartilhada, sem registro	2 x 5 = 10	Alto	Acesso nominal e registro
R10 Descumprimento da LGPD	Sem mapeamento de dados nem encarregado	3 x 4 = 12	Alto	Programa de privacidade
R11 Uso indevido de IA com dados pessoais	Sem política nem orientação	4 x 3 = 12	Alto	Política de IA e treinamento

Risco	Vulnerabilidades prováveis	P x I	Classe	Tratamento principal
R12 Perda ou roubo de notebook	Disco sem criptografia	3 x 3 = 9	Médio	Criptografia e bloqueio remoto

Os riscos R1 e R2 têm prioridade máxima, pois combinam alta probabilidade e alto impacto e se relacionam: o phishing costuma ser a porta de entrada do ransomware. Sempre restará um risco residual, que deve ser revisado periodicamente.

4. Medidas de segurança recomendadas

O plano usa **defesa em profundidade**: várias camadas de proteção, de modo que a falha de uma não comprometa todo o ambiente. As prioridades são P1 (crítica), P2 (alta) e P3 (média).

4.1 Rede (P1)

O que fazer: dividir a rede em segmentos (VLANs, redes virtuais separadas) e controlá-los por um firewall de próxima geração, com a regra de negar por padrão. **Por quê:** impede que um computador infectado alcance os servidores.

VLAN	Segmento	Regra de comunicação
10	Administração	Acessa apenas os sistemas autorizados
20	Professores	Sistema acadêmico e arquivos pedagógicos
30	Alunos (Wi-Fi)	Internet e portal acadêmico; clientes isolados entre si
40	Laboratórios (3 sub-redes)	Internet filtrada e autenticação; isolados entre si e dos servidores
50	Servidores	Sem acesso direto à Internet; só regras específicas
60	Gerenciamento	Acessível somente pelas estações da TI
70	Visitantes	Somente Internet
80	Backup	Acessível apenas aos servidores de backup e à TI

- **Wi-Fi:** rede corporativa com login individual (WPA2/WPA3-Enterprise), rede de alunos com conta institucional e rede de visitantes isolada.
- **VPN** (túnel criptografado) com MFA para qualquer acesso remoto; acesso administrativo apenas por VPN.
- **Monitoramento:** logs de firewall, switches e servidores centralizados e com alertas.

A capacidade dos switches (VLAN, 802.1X) e do firewall atual deve ser verificada no diagnóstico.

4.2 Datacenter e servidores (P1/P2)

- **Acesso físico:** entrada nominal (cartão ou biometria), registro de entradas, câmeras, no-break e sensores de temperatura e fumaça.
- **Hardening** (reduzir a superfície de ataque): desativar serviços e protocolos obsoletos, trocar senhas padrão, seguir configurações seguras (por exemplo, CIS Benchmarks).
- **Atualizações:** ciclo mensal e correção emergencial de falhas críticas.
- **Privilégios:** contas administrativas separadas das de uso diário, com MFA; acesso por servidor de salto.
- **Proteção contra malware:** EDR (antivírus avançado com detecção de comportamento) também nos servidores.
- **Auditoria:** logs de login, mudanças de permissão e acesso a pastas sensíveis, guardados por período a definir com o jurídico.

4.3 Servidores de arquivos (P1)

- Permissões por **grupo**, seguindo o **menor privilégio** (cada pessoa acessa só o necessário); remover acessos amplos como “Todos”.
- Pastas restritas (financeiro, RH, dados de alunos) com acesso nominal e registro.
- Cópias de sombra (snapshots) para recuperar arquivos apagados ou criptografados; bloqueio de extensões típicas de ransomware.
- Criptografia dos volumes com dados restritos e proibição de guardar dados institucionais em dispositivos pessoais.

4.4 Laboratórios de informática (P2)

Os 90 computadores precisam permitir aulas práticas sem comprometer a rede. A estratégia é **permitir liberdade dentro de um ambiente restaurável e isolado**.

- Gerenciamento central (domínio, políticas de grupo), imagem padrão e atualizações fora do horário de aula.
- Contas individuais de aluno sem administrador local; senha de administrador local única por máquina.
- Software autorizado por disciplina, com pedido antecipado do professor (prazo sugerido: 5 dias úteis).
- Restauração da estação a cada reinício ou reimagem periódica, para que cada aula comece em estado limpo.
- Disciplinas que exigem privilégios elevados (redes, sistemas operacionais) usam máquinas virtuais em rede isolada.
- Antivírus gerenciado, bloqueio de mídias removíveis não autorizadas e filtro de DNS.

4.4.1 Computadores e notebooks da equipe (P1/P2)

- Inventário atualizado, sistemas com suporte e atualização automática.
- **Criptografia de disco** nos notebooks (chaves de recuperação guardadas pela TI) e bloqueio de tela em 5 a 10 minutos.
- Antivírus/EDR gerenciado; usuários sem administrador; catálogo de software aprovado.
- Acesso remoto somente por VPN com MFA; mídias removíveis bloqueadas por padrão em estações com dados sensíveis.
- **Perda ou roubo:** comunicar a TI imediatamente (meta: até 2 horas), bloquear conta, revogar sessões e, se possível, apagar remotamente.

4.5 Identidades e acessos (P1)

- **Contas individuais e nominais**; criação mediante solicitação formal (RH para equipe, secretaria para alunos).
- **Desligamento:** desativar contas em até 24 horas (imediato em casos sensíveis). Revisar permissões a cada semestre.
- **MFA** (confirmação em dois fatores): obrigatório já para administradores, e-mail e VPN; depois, para professores e funcionários. Para alunos, avaliar a viabilidade, ao menos em serviços com dados pessoais.

- **Senhas:** longas (sugestão: 12 caracteres ou mais para a equipe), sem troca periódica forçada, bloqueio de senhas comuns ou vazadas e limite de tentativas, conforme diretrizes do NIST SP 800-63B.
- Administradores usam contas separadas, com uso registrado e revisão trimestral dos grupos privilegiados.

4.6 Site e aplicativo (P2)

A segurança é **compartilhada**: o fornecedor protege a infraestrutura, mas o IEH continua responsável pelos dados e pela escolha do fornecedor.

- **Site:** HTTPS, atualização do sistema de conteúdo e plugins, acesso administrativo com MFA, firewall de aplicação (WAF), backup com teste de restauração e monitoramento do domínio e do certificado.
- **Aplicativo:** boas práticas do OWASP, autenticação e autorização verificadas no servidor, proteção das APIs (limite de requisições, validação), criptografia em trânsito e em repouso, segredos fora do código, atualização de componentes e **teste de invasão (pentest) antes de versões relevantes e ao menos uma vez por ano**.
- **Contratos:** exigir cláusulas de segurança, LGPD, aviso de incidentes em prazo curto (sugestão: 24 horas), SLA, backups e metas de recuperação, direito de auditoria e devolução ou eliminação dos dados ao final.

4.7 Proteção de dados e LGPD (P1/P2)

O IEH é **controlador** dos dados pessoais e deve designar um **encarregado (DPO)**, canal com titulares e ANPD. Dados de crianças e adolescentes exigem atenção especial (art. 14 da LGPD).

Medida	Descrição
Mapeamento	Registrar quais dados são tratados, para quê, onde ficam, quem acessa e com quem são compartilhados
Finalidade e minimização	Coletar apenas o necessário, com finalidade e base legal definidas
Retenção e descarte	Tabela de prazos e descarte seguro ao fim do prazo
Fornecedores	Contratos com cláusulas de proteção de dados
Direitos dos titulares	Canal e fluxo para atender solicitações
Relatório de impacto (RIPD)	Para tratamentos de maior risco, como biometria e dados de menores em larga escala

Obrigação legal: medidas de segurança (art. 46), encarregado (art. 41), direitos dos titulares (art. 18) e comunicação de incidente relevante (art. 48). **Recomendação técnica:** MFA, segmentação, backup imutável e demais controles deste plano. **Exigem validação jurídica:** bases legais, dados de menores, prazos de retenção, contratos e transferência internacional de dados. Este plano não substitui parecer jurídico.

4.8 Backup e recuperação de desastres (P1)

- **Regra 3-2-1:** três cópias dos dados, em dois tipos de mídia, uma fora do local. Recomenda-se ainda uma cópia **imutável ou offline** (que não pode ser apagada nem por quem tenha acesso à rede) e verificação por testes.
- **RPO** (quanto de dados se aceita perder) e **RTO** (quanto tempo se aceita ficar parado), definidos por sistema.
- Backups criptografados, em rede isolada (VLAN 80), com credenciais separadas e alertas de exclusão.
- **Testes de restauração:** mensais por amostragem, trimestrais para sistemas críticos e um teste completo por ano. Um backup só é confiável se a restauração foi testada.

Sistema	RPO	RTO
Diretório de contas	4 h	4 h
Sistema acadêmico e banco de dados	1 a 4 h	4 a 8 h
Servidores de arquivos	24 h (4 h em pastas críticas)	8 a 24 h
Sistema financeiro	24 h	24 h
Site e aplicativo	24 h (aplicativo: 4 a 24 h)	24 a 48 h (aplicativo: 8 a 24 h)
Estações de laboratório	Não se aplica	1 dia (reimagem)

Metas sugeridas, a validar com as áreas do IEH. Retenção sugerida: diária por 30 dias, semanal por 8 semanas e mensal por 12 meses (validar com o jurídico).

5. Políticas e responsabilidades

5.1 Políticas de segurança

As políticas transformam as decisões técnicas em regras formais, aprovadas pela direção, divulgadas e revisadas ao menos uma vez por ano.

Política	Regras fundamentais
Geral de Segurança da Informação	Escopo, princípios, responsabilidades, sanções e revisão anual; base das demais
Controle de Acesso	Contas individuais, menor privilégio, MFA, revisão semestral, desativação no desligamento
Uso Aceitável de TI	Uso institucional, proibição de software pirata e de burla de controles, termo de ciência
Backup e Restauração	Regra 3-2-1, RPO e RTO, cópia imutável, testes e retenção
Segurança de Endpoints	Inventário, criptografia, antivírus, atualizações, sem administrador local, comunicação de perda
Gestão de Incidentes	Canal único, classificação, comitê de resposta e comunicação a ANPD e titulares
Privacidade e Proteção de Dados	Finalidade, minimização, direitos dos titulares, retenção, proteção de dados de menores
Acesso Remoto	VPN com MFA, equipamentos gerenciados, ferramentas homologadas
Gestão de Fornecedores	Avaliação prévia, cláusulas de segurança e LGPD, aviso de incidentes, saída segura
Uso de Inteligência Artificial	Não inserir dados pessoais ou restritos em ferramentas não aprovadas; revisão humana dos resultados; integridade acadêmica

5.2 Conscientização e treinamento

Tecnologia sozinha não impede ataques que exploram o comportamento humano. O programa prevê: treinamento inicial e microtreinamentos mensais para professores e funcionários; simulações trimestrais de phishing, com foco educativo e sem punição; módulo de integração e campanhas semestrais para alunos; e workshops de decisão para a direção. Temas: phishing, senhas e MFA, proteção de dados, uso seguro da internet e de IA e como comunicar incidentes.

5.3 Governança e responsabilidades

Propõe-se um **Comitê de Segurança da Informação e Privacidade** (direção, TI, jurídico, encarregado e representantes das áreas), com reuniões mensais durante a implantação e trimestrais depois.

Papel	Principais responsabilidades
Direção	Patrocinar o plano, aprovar políticas e orçamento, decidir em crises e dar o exemplo
Coordenação de TI/Segurança	Executar e operar os controles, manter inventário, indicadores e resposta técnica a incidentes
Equipe de TI	Atualizações, backups, monitoramento, gestão de contas e acessos
Encarregado (DPO)	Orientar sobre a LGPD, atender titulares e ANPD, apoiar a avaliação de incidentes
Jurídico	Validar contratos, bases legais e comunicações oficiais
Donos da informação (gestores)	Classificar dados, aprovar acessos e participar da revisão semestral
Professores e funcionários	Cumprir as políticas, proteger dados e relatar incidentes
Fornecedores	Cumprir cláusulas de segurança e LGPD e comunicar incidentes

Em equipe pequena, uma pessoa pode acumular papéis, mas quem administra os sistemas não deve ser o único a auditá-los.

6. Plano de implementação e prioridades

A implantação começa pelos controles que mais reduzem os riscos R1 e R2. Prazos e responsáveis são **estimativas** e dependem do diagnóstico e do orçamento aprovado.

Fase	Ação	Prior.	Responsável	Resultado esperado
1. Até 30 dias	Aprovar o plano, formar o comitê e liberar orçamento da fase	P1	Direção	Governança definida
	Diagnóstico técnico (ativos, vulnerabilidades, premissas)	P1	TI + consultoria	Inventário e relatório de lacunas
	Proteger o backup (cópia isolada/imutável) e testar restauração	P1	TI	Recuperação comprovada dos sistemas críticos
	MFA para administradores, e-mail e VPN	P1	TI	100% das contas privilegiadas com MFA
	Revisar contas e corrigir falhas críticas; antivírus em todos os equipamentos	P1	TI	Contas inativas removidas; cobertura medida
	Designar encarregado (DPO); definir canal de incidentes	P2	Direção + Jurídico	Responsável e fluxo definidos
2. 31 a 90 dias	Firewall e segmentação inicial; Wi-Fi seguro	P1/P2	TI + integrador	VLANs de servidores, gerência e visitantes
	MFA para professores e funcionários; criptografia de notebooks	P1	TI	Adesão de 90% ou mais; 100% dos notebooks
	Gestão central dos laboratórios; revisão de permissões dos arquivos	P1/P2	TI + gestores	Laboratórios padronizados; menor privilégio
	Políticas essenciais; mapeamento inicial de dados; revisão de contratos; treinamento inicial	P1/P2	Comitê, DPO, Jurídico, RH	Regras formais e primeiros treinamentos

Fase	Ação	Prior.	Responsável	Resultado esperado
3. 3 a 6 meses	Segmentação completa, logs centralizados e hardening dos servidores	P1/P2	TI	Matriz de comunicação implantada
	Plano de recuperação de desastres e teste completo de restauração	P1	TI + Direção	RPO e RTO medidos
	Teste de invasão do aplicativo e do site; controle físico do datacenter	P2	Fornecedor/consultoria, TI	Falhas corrigidas; acesso nominal
	Demais políticas; treinamento de alunos; exercício de simulação de ransomware	P2/P3	Comitê	Cultura de segurança em curso
4. 6 a 12 meses	Auditoria interna, revisão dos riscos com dados reais e primeira recertificação de acessos	P2	Comitê + auditoria	Riscos e acessos atualizados
	Teste de recuperação completo; avaliação de maturidade; decisão sobre MDR/SOC e ISO 27001	P1/P3	TI + Direção	Plano de melhoria para o ciclo seguinte

6.1 Investimento estimado

Os valores são **estimativas de ordem de grandeza, não cotações**, e devem ser substituídos por pelo menos três cotações formais. Premissas: cerca de 230 usuários internos, 120 estações da equipe, 90 de laboratório, 2 a 4 servidores físicos e horizonte de 12 meses. Horas internas, contratação de pessoal e substituição de equipamentos obsoletos não foram incluídas.

Cenário	Inicial (R$)	Recorrente por ano (R$)	Cobertura principal
Essencial	120 mil a 195 mil	93 mil a 153 mil	Backup, MFA, firewall e antivírus gerenciados, treinamento; segmentação parcial
Intermediário (recomendado como meta em 12 meses)	310 mil a 485 mil	225 mil a 380 mil	Segmentação completa, Wi-Fi seguro, logs, plano de recuperação testado e monitoramento terceirizado
Avançado	690 mil a 1,17 milhão	525 mil a 900 mil	Alta resiliência, monitoramento 24 horas, gestão de privilégios e preparação para a ISO/IEC 27001

Recomendação: iniciar pelo cenário essencial nos primeiros 90 dias e evoluir para o intermediário conforme o diagnóstico e a capacidade de investimento.

7. Resposta a incidentes e recuperação

Um incidente pode ocorrer mesmo com os controles. O processo abaixo, alinhado ao NIST SP 800-61 e ao NIST CSF 2.0, define o que fazer e quem responde.

Etapa	O que fazer
1. Detecção e registro	Receber alertas e relatos por canal único; registrar data, hora, sistemas e sintomas
2. Classificação	Definir a gravidade: Crítico (ransomware, parada de serviço essencial, vazamento de dados sensíveis), Alto (conta privilegiada comprometida), Médio (phishing com um clique) ou Baixo
3. Contenção	Isolar equipamentos e segmentos, bloquear contas e acessos suspeitos
4. Investigação	Coletar logs e evidências; identificar origem, alcance e dados afetados

Etapa	O que fazer
5. Erradicação e recuperação	Remover a causa, reconstruir ou restaurar a partir de cópias limpas e validar antes de religar
6. Comunicação	Informar direção, DPO e jurídico; avaliar a comunicação à ANPD e aos titulares, conforme a regulamentação vigente (Resolução CD/ANPD nº 15/2024, cujo prazo deve ser confirmado pelo jurídico)
7. Lições aprendidas	Relatório do incidente, ações corretivas e atualização dos riscos e treinamentos

7.1 Cenários principais

Cenário	Ações imediatas	Depois
Ransomware	Isolar a máquina e o segmento (sem desligar, se possível), bloquear contas, acionar o comitê	Identificar o vetor, reconstruir servidores, restaurar do backup limpo, trocar credenciais e avaliar comunicação à ANPD. Pagar resgate só após decisão da direção com avaliação jurídica
Conta comprometida	Trocar senha, revogar sessões, exigir MFA, verificar regras de e-mail suspeitas	Revisar logs e dados acessados; avisar os afetados
Vazamento de dados	Conter a exposição, preservar evidências, acionar DPO e jurídico	Identificar titulares e dados, avaliar risco e comunicar conforme a lei
Roubo de notebook	Bloquear conta e dispositivo, revogar sessões, apagar remotamente se possível	Confirmar criptografia, avaliar dados armazenados, registrar boletim de ocorrência
Indisponibilidade do datacenter	Acionar o plano de recuperação, verificar energia, climatização e rede	Restaurar sistemas críticos conforme o RTO e, se necessário, ativar ambiente alternativo (nuvem)

A recuperação segue esta ordem: infraestrutura e diretório de contas, sistemas críticos (acadêmico, financeiro), servidores de arquivos e, por último, sistemas de menor criticidade. A equipe de resposta reúne coordenador de TI, analista de segurança, DPO, jurídico e representante da direção, com plantão para incidentes críticos.

8. Monitoramento e revisão do plano

O plano será acompanhado por indicadores revisados mensalmente pelo comitê. As **metas abaixo são sugestões** e devem ser ajustadas depois de medida a situação inicial no diagnóstico.

Indicador	Como medir	Meta sugerida (12 meses)
Equipamentos atualizados	% de estações e servidores com sistema suportado e patches críticos em até 30 dias	95% ou mais
Cobertura de proteção	% de dispositivos com antivírus/EDR ativo	98% ou mais
Sucesso dos backups e restaurações	% de rotinas concluídas e testes de restauração bem-sucedidos	98% ou mais; 100% dos testes planejados
Uso de MFA	% de contas elegíveis com MFA	Administradores 100%; equipe 95% ou mais
Vulnerabilidades críticas pendentes	Número em aberto há mais de 15 dias	Zero
Incidentes	Número por gravidade e tempo de resposta	Tendência de queda no tempo de resposta
Phishing simulado	Taxa de cliques e de relatos	Cliques abaixo de 10%
Desligamentos	% de contas desativadas em até 24 horas	100%

Indicador	Como medir	Meta sugerida (12 meses)
Conclusão das ações do plano	% de ações concluídas no prazo	85% ou mais por fase
LGPD e fornecedores	% de tratamentos mapeados; fornecedores críticos com cláusulas	90% ou mais; 100%

- **Revisões:** matriz de riscos e acessos revisadas a cada semestre; políticas ao menos uma vez por ano e após incidentes relevantes.
- **Auditoria:** auditoria interna ou independente, varredura mensal de vulnerabilidades, teste de invasão anual e exercício de simulação de crise a cada semestre.
- O número de incidentes registrados pode aumentar no início, porque a detecção melhora; deve ser lido junto com a gravidade e o tempo de resposta.

9. Conclusão

O plano organiza a proteção do IEH em camadas — rede, servidores, laboratórios, computadores, identidades, site, aplicativo e dados — sustentadas por políticas, treinamento e governança. Prioriza o que mais reduz os riscos de ransomware e phishing: backup protegido e testado, MFA, segmentação, atualizações e conscientização.

Os resultados esperados são menor probabilidade e menor impacto de incidentes, recuperação mais rápida, maior visibilidade sobre ativos e acessos e um caminho estruturado para a LGPD. Esses resultados dependem de diagnóstico, implantação, testes e medição por indicadores, e a conformidade legal exige validação jurídica. A segurança da informação é um processo contínuo e depende do apoio da direção.

Primeiras ações recomendadas: (1) aprovar o plano e formar o comitê; (2) realizar o diagnóstico técnico; (3) garantir uma cópia de backup isolada com restauração testada; (4) ativar MFA nas contas privilegiadas, no e-mail e na VPN; (5) designar o encarregado de dados.

10. Referências

Conferir a edição e a versão vigentes nos sites dos respectivos órgãos antes da citação formal. Os valores monetários deste plano não derivam de fonte externa: são estimativas elaboradas para este trabalho.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO/IEC 27001:2022** — Segurança da informação, segurança cibernética e proteção da privacidade — Sistemas de gestão da segurança da informação — Requisitos. Rio de Janeiro: ABNT, 2022.

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). **ABNT NBR ISO/IEC 27002:2022** — Controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION (ISO); INTERNATIONAL ELECTROTECHNICAL COMMISSION (IEC). **ISO/IEC 27005** — Guidance on managing information security risks (edição vigente). Disponível em: iso.org.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **The NIST Cybersecurity Framework (CSF) 2.0**. NIST CSWP 29. 2024. Disponível em: nist.gov.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **SP 800-61** — Incident Response Recommendations and Considerations for Cybersecurity Risk Management (revisão vigente); **SP 800-63B** — Digital Identity Guidelines: Authentication and Authenticator Management (revisão vigente). Disponível em: nist.gov.

CENTER FOR INTERNET SECURITY (CIS). **CIS Critical Security Controls** (versão 8 ou 8.1, conforme edição vigente) e **CIS Benchmarks**. Disponível em: cisecurity.org.

OPEN WORLDWIDE APPLICATION SECURITY PROJECT (OWASP). **OWASP Top 10**, **API Security Top 10** e **MASVS**. Disponível em: owasp.org.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018** — Lei Geral de Proteção de Dados Pessoais (LGPD). Disponível em: planalto.gov.br.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). **Resolução CD/ANPD nº 15, de 24 de abril de 2024** — Regulamento de Comunicação de Incidente de Segurança; e **Guia Orientativo de Segurança da Informação para Agentes de Tratamento de Pequeno Porte** (2021). Disponível em: gov.br/anpd.